Zephyr-Image signieren und prüfen

Signieren, Metadaten lesen, Manipulation erkennen

5.06

Übungsablauf auf einen Blick

SCHLÜSSEL

Trainingsschlüssel nutzen

Privaten Signierschlüssel und öffentlichen Prüfschlüssel eindeutig zuordnen.

SIGNIEREN

Zwei Wege vergleichen

Image direkt mit imgtool und aus dem Build heraus mit west sign erzeugen.

PRÜFEN

Metadaten auswerten

Header, TLVs und Signatur vor und nach Änderung prüfen.

Schlüsselgenerierung, Skripte und vollständige Projektkonfiguration liefert das Übungsprojekt.

Eingaben und Parameter

Privater Schlüssel	signiert ausschließlich Trainingsartefakte
Öffentlicher Schlüssel	bildet die Vertrauensbasis für die Prüfung
Anwendungsimage	liefert die unveränderte Nutzlast
Imagegeometrie	Header Size, Slot Size und Alignment müssen passen
Imageversion	wird als strukturierte Versionsangabe eingebettet

Private Schlüssel nie in Quellcode, Logs oder freigegebene Artefakte übernehmen.

Fünf Schritte zum signierten Image

Die Übung konzentriert sich auf Werkzeugkette und beobachtbare Imageänderungen

01

Vorbereiten

Trainingsschlüssel und Ausgangsimage auswählen

02

Parametrieren

Header Size, Slot Size und Version festlegen

03

Signieren

imgtool und west sign ausführen

04

Auslesen

Imageheader und TLV-Einträge anzeigen

05

Vergleichen

unsigniertes, signiertes und verändertes Image prüfen

Jeder Schritt erzeugt ein separates Artefakt; das Ausgangsimage bleibt unverändert.

imgtool und west sign

WERKZEUGWEGE

```
imgtool sign …
west sign -t imgtool …
```

IMGTOOL	signiert ein benanntes Image mit expliziten Parametern
WEST SIGN	nutzt Buildinformationen und ruft das Signierwerkzeug auf
PARAMETER	Version, Schlüssel und zusätzliche Optionen bleiben nachvollziehbar
ERGEBNIS	MCUboot-kompatibles Image mit Header und Signatur-TLV

Beide Wege müssen dieselbe Imagegeometrie und denselben Vertrauensanker verwenden.

Gepaddet oder ungepaddet

01	`Ungepaddetes Image`	endet nach Payload und TLV-Bereich
02	`Gepaddetes Image`	wird bis zur Slotgröße erweitert und kann Trailerdaten enthalten
03	`Passende Geometrie`	Header Size, Slot Size und Alignment müssen zum Ziel passen

Padding verändert das Containerlayout, nicht die fachliche Nutzlast der Anwendung.

Header und TLVs auslesen

INSPEKTION

```
imgtool dumpinfo zephyr.signed.bin


Header → Version / Größe / Flags
TLVs   → Hash / Signatur / Schlüsselinfo
```

01 Struktur prüfen

Headerfelder und TLV-Typen mit den gewählten Parametern abgleichen.

02 Manipulation erkennen

Nachträgliche Nutzlaständerungen machen Hash und Signatur ungültig.

Eine Signatur schützt die gebundenen Bytes; jede spätere Änderung bricht die Verifikation.

Drei Imagevarianten im Vergleich

UNSIGNIERT

Ohne Nachweis

Es fehlt eine vertrauenswürdig prüfbare Signatur für den Bootloader.

SIGNIERT

Verifizierbar

Header, Hash und Signatur passen zum unveränderten Image.

VERÄNDERT

Abgelehnt

Eine geänderte Nutzlast passt nicht mehr zu Hash und Signatur.

Der Vergleich trennt Dateiformat, Integrität und kryptografische Authentizität.